CASE STUDY

The SharePoint ToolShell Mass Exploitation: A 2025 Case Study

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

In July 2025 a chain of flaws in on-premises Microsoft SharePoint Server, known collectively as ToolShell, went from a conference demonstration to worldwide mass exploitation in a matter of days. The decisive move was not the remote code execution itself but what the attackers did next: they stole the SharePoint server's ASP.NET machine keys. With those keys an attacker can forge signed `__VIEWSTATE` payloads and regain code execution at will, which means a server that is merely patched is still compromised. More than 400 servers across roughly 148 organizations were hit, including the US National Nuclear Security Administration, and three China-linked actors (Linen Typhoon, Violet Typhoon, and Storm-2603) used the access for espionage and, in Storm-2603's case, to deploy Warlock and LockBit ransomware. The case is the clearest recent lesson that for a secret-stealing vulnerability, remediation is patch plus key rotation, not patch alone.

> Evidence grade: **Confirmed** overall (Microsoft, CISA, and multiple vendor and victim sources; single-source figures are marked below).

Key facts at a glance

Field	Value
Patch-bypass pair	CVE-2025-53770 (deserialization, CVSS 9.8) and CVE-2025-53771 (path traversal, CVSS 6.3), unauthenticated, chained for RCE
Original pair bypassed	CVE-2025-49704 (code injection) and CVE-2025-49706 (spoofing), fixed in the July 2025 Patch Tuesday
Affected	SharePoint Subscription Edition, Server 2019, Server 2016 (on-premises only); SharePoint Online not affected

Field	Value
Decisive technique	Theft of the ASP.NET `ValidationKey` and `DecryptionKey` via `spinstall0.aspx` , enabling forged `__VIEWSTATE` RCE
Remediation	Patch, then rotate machine keys, then `iisreset` on every farm server; patch alone is not enough
Actors	Linen Typhoon, Violet Typhoon (espionage), Storm-2603 (Warlock and LockBit ransomware)
First exploitation	Observed from around 18 July 2025, days after the July patch
Scale	More than 400 servers across about 148 organizations; the US NNSA confirmed breached

Key findings

- **It was a patch bypass, exploited within days of the patch.** Microsoft's July 2025 update fixed the original ToolShell pair (CVE-2025-49706 spoofing and CVE-2025-49704 code injection). Attackers bypassed those fixes with CVE-2025-53770 (deserialization of untrusted data, CVSS 9.8) and CVE-2025-53771 (path traversal, CVSS 6.3), unauthenticated and chained for remote code execution, and exploitation was observed from about 18 July 2025.
- **On-premises only; SharePoint Online was not affected.** The flaws hit SharePoint Subscription Edition, SharePoint Server 2019 and SharePoint Server 2016. The Microsoft 365 cloud service was not vulnerable, which concentrated the damage on self-managed servers that are harder to patch quickly.
- **Machine-key theft turned a patch into a non-fix.** Post-exploitation deployed a file named `spinstall0.aspx` whose purpose was to read and exfiltrate the server's ASP.NET `ValidationKey` and `DecryptionKey` . Those keys let the attacker sign malicious `__VIEWSTATE` objects that SharePoint deserializes and executes, so persistence survives patching until the keys are rotated.
- **Three China-linked actors, espionage and ransomware.** Microsoft attributed activity to Linen Typhoon and Violet Typhoon (state-linked espionage) and to Storm-2603, which stole machine keys and deployed Warlock and LockBit ransomware. The same unauthenticated entry point served both long-term collection and smash-and-grab extortion.
- **The scale was large and the victims were sensitive.** Reporting put the campaign at more than 400 compromised servers across about 148 organizations on four continents, including government agencies, universities, telecommunications and finance, and the US National Nuclear Security Administration confirmed it was among those breached (no classified data reported affected).

Top recommendations

1. For any SharePoint touched before patching, assume the machine keys are stolen: patch to the fixed build, then rotate the ASP.NET machine keys and run `iisreset` on every server in the farm. A patch without key rotation leaves the attacker's forged-payload path open.

2. Hunt for the indicators, do not just scan for the version: look for `spinstall0.aspx` and similar dropped files, unexpected `w3wp.exe` child processes, and anomalous `ToolPane.aspx` POST requests, because an already-compromised server can pass a version check.
3. Treat internet-facing on-premises collaboration servers as edge devices on the shortest patch clock, and prefer taking an unpatchable SharePoint server offline over leaving it exposed, as CISA advised.
4. Inventory where ASP.NET machine keys and other signing secrets live, and build key rotation into incident response so it is a practiced step, not an improvised one.

Scope and method

This study covers the ToolShell SharePoint exploitation of July 2025, from Microsoft, CISA, and vendor and victim sources. Each claim carries one of three evidence grades.

Grade	Meaning
Confirmed	Microsoft, CISA, or the victim organization confirms the exploitation or compromise
Reported	A single vendor or press account, not independently corroborated
Demonstrated	A research reproduction with no known in-the-wild use at the time

Part 1: the vulnerability chain

ToolShell began as research. At Pwn2Own Berlin in May 2025, researchers demonstrated a SharePoint exploit chain, and Microsoft issued fixes in its July 2025 Patch Tuesday for the two flaws that chain relied on (**Confirmed**):

- **CVE-2025-49706**: a spoofing and authentication-bypass flaw that lets a request reach a privileged endpoint.
- **CVE-2025-49704**: a code-injection flaw (CVSS 8.8) that turns that reach into remote code execution.

Within days, a public reproduction appeared (Code White reported a working reproduction on 14 July 2025), and attackers found that the July fixes could be bypassed. Microsoft assigned two new identifiers for the bypass (**Confirmed**):

- **CVE-2025-53770**: deserialization of untrusted data in on-premises SharePoint, CVSS 9.8, a variant of CVE-2025-49704, allowing unauthenticated remote code execution over the network.
- **CVE-2025-53771**: a path-traversal and spoofing flaw, CVSS 6.3, a variant of CVE-2025-49706.

Chained, the two give an unauthenticated attacker code execution on an internet-reachable SharePoint server. The attack typically lands as a crafted POST to the `ToolPane.aspx` endpoint. CISA added CVE-2025-53770 to its Known Exploited Vulnerabilities catalog on 20 July 2025, and Microsoft shipped

out-of-band updates for Subscription Edition and Server 2019 on 19 to 20 July, with a Server 2016 update following (**Confirmed**).

The timeline is the first lesson: a vulnerability can move from a patched Patch-Tuesday item to an actively exploited zero-day bypass in under a week. A monthly patch cadence does not survive that.

Timeline

Date (2025)	Event
May	ToolShell exploit chain demonstrated at Pwn2Own Berlin
July Patch Tuesday	Microsoft fixes CVE-2025-49704 and CVE-2025-49706
14 July	Code White reports a working public reproduction of the chain
Around 18 July	Mass exploitation of the CVE-2025-53770 and CVE-2025-53771 bypass begins
19 to 20 July	Microsoft ships out-of-band updates (Subscription Edition, Server 2019; Server 2016 follows)
20 July	CISA adds CVE-2025-53770 to the Known Exploited Vulnerabilities catalog

Part 2: why patching alone did not fix it

The defining feature of ToolShell is what happened after code execution. The attackers' goal was not only a web shell but the server's cryptographic secrets.

How ViewState trust works

ASP.NET protects `__VIEWSTATE`, the serialized control state a SharePoint page round-trips through the browser, with a message authentication code keyed by the server's `ValidationKey`, and optionally encrypts it with the `DecryptionKey`. These machine keys are what let the server trust that a `__VIEWSTATE` blob it receives is one it issued: when a request comes back carrying a `__VIEWSTATE`, the server checks the signature against its key, and if it validates, deserializes the contents. The whole mechanism rests on the keys staying secret. If an attacker learns them, the trust model inverts, because now the attacker can produce blobs the server will accept as its own.

The theft

The post-exploitation payload, commonly the file `spinstall0.aspx`, read the validation and decryption keys out of the server configuration and sent them to the attacker (**Confirmed**: CISA malware analysis and multiple vendors). With those keys, an attacker no longer needs the vulnerability. They can craft a `__VIEWSTATE` payload containing a malicious serialized object, sign it with the stolen key, and send it to the server, which validates the signature, deserializes the object, and runs it, as the SharePoint application identity. This is why a server that was exploited and then merely patched is still owned: the patch closes the entry door while the attacker keeps a signed key to a different one.

The remediation order

Remediation therefore required three steps, in order (**Confirmed**: Microsoft guidance):

1. Apply the fixed security update.
2. Rotate the ASP.NET machine keys (`Update-SPMachineKey` through PowerShell or the Machine Key Rotation timer job in Central Administration).
3. Restart IIS with `iisreset.exe` on every server in the farm so the new keys take effect.

For a vulnerability management program, this is the transferable point: a flaw that leaks a long-lived secret converts "time to patch" into "time to patch and rotate." Closing the finding in the scanner, which keys on the build number, does not mean the host is clean.

ToolShell remediation and detection

Step	What to do
Patch	Update to the fixed build for your edition (Subscription Edition, Server 2019 via KB5002754 and its pair, Server 2016); confirm the farm build, not just one server
Rotate keys	Rotate ASP.NET machine keys on every SharePoint server (`Update-SPMachineKey` or the Central Administration job), then `iisreset` so forged `__VIEWSTATE` payloads signed with the old key stop working
Hunt	Search for `spinstall0.aspx` and other unexpected `.aspx` files in the LAYOUTS path, suspicious POSTs to `ToolPane.aspx` , and `w3wp.exe` spawning `cmd.exe` or `powershell.exe`
Reduce exposure	Enable AMSI full mode and an endpoint agent on SharePoint, put the server behind authenticated access or a VPN, and take any unpatchable server offline
Assume breach	If the server was internet-facing and unpatched between roughly 18 and 21 July 2025, treat it as compromised, rotate secrets, and investigate, do not assume the later patch was in time

Per-edition and per-technology remediation

The remediation is the same shape everywhere (patch, rotate keys, `iisreset`), but the exact build and the supporting controls differ by edition and technology (**Confirmed**: Microsoft guidance):

Platform or technology	How to remediate
SharePoint Subscription Edition	Apply the 19 to 20 July 2025 out-of-band update, confirm the farm build, then rotate machine keys and `iisreset`

Platform or technology	How to remediate
SharePoint Server 2019	Apply the fixed build (KB5002754 and its pair), confirm across the farm, rotate keys and `iisreset`
SharePoint Server 2016	Apply the follow-on 2016 update when available, then rotate keys and `iisreset` ; until then, reduce exposure or take offline
SharePoint Online (Microsoft 365)	Not affected; no action, which is itself the argument for the managed service where feasible
ASP.NET machine keys (IIS)	Rotate `ValidationKey` and `DecryptionKey` with `Update-SPMachineKey` or the Central Administration timer job, then `iisreset.exe` on every farm server so forged `__VIEWSTATE` payloads stop validating
Microsoft Defender / AMSI	Enable AMSI in full mode on SharePoint and keep an endpoint agent running, so a dropped web shell and `w3wp.exe` spawning shells are caught
Network and edge	Put the server behind authenticated access or a VPN, block or inspect POSTs to `ToolPane.aspx` at a WAF, and take any unpatchable server offline as CISA advised
OpenShift and containerized hosts	Apply Red Hat's interim guidance; note a host-level network rule covers only the host namespace, not pod-to-pod traffic
SIEM and detection	Alert on `spinstall0.aspx` and other unexpected `.aspx` files in the LAYOUTS path, anomalous `ToolPane.aspx` POSTs, and new administrator accounts

Part 3: who exploited it, and the scale

Microsoft attributed the exploitation to three China-linked actors, with different aims (**Confirmed**: Microsoft):

- **Linen Typhoon**: a state-linked group using the access for espionage and long-term collection, associated with intellectual-property-focused intrusions.
- **Violet Typhoon**: a state-linked espionage group focused on reconnaissance and data collection against government, academic and NGO targets.
- **Storm-2603**: a China-linked actor that stole machine keys and, from 18 July 2025, deployed ransomware (Warlock and LockBit) on compromised SharePoint servers. Microsoft noted Storm-2603 had no clear ties to the other two groups.

The same unauthenticated foothold thus fed both quiet espionage and loud extortion, a reminder that an exposure does not get to choose who finds it. The gap between espionage and ransomware operators collapses when they enter through the same unauthenticated door.

Scale estimates vary by what they count (**Reported** except where noted):

- More than 400 compromised servers across about 148 organizations within weeks of the first wave, on four continents.
- Targets spanned government, universities, telecommunications, finance, and critical-infrastructure operators including water and telecom.
- The **US National Nuclear Security Administration confirmed** it was breached through the ToolShell chain, with no classified data reported affected (**Confirmed**: agency statement).
- By September 2025, Warlock's leak site listed roughly 60 victims, a floor rather than a full count, since groups often omit victims who pay quickly.

Part 4: the vulnerability-management lens

ToolShell is a case about what "remediated" means, and a program that takes the wrong definition will carry owned hosts as clean:

- **The scanner lies when the secret is gone.** Vulnerability scanners key on the patch level or build number. A server that was exploited before patching and then patched will report as not vulnerable while the attacker still holds its machine keys. The scanner is answering "is the door locked," not "did someone copy the key." For secret-stealing flaws, close-the-finding and close-the-incident are different events.
- **Patch bypasses break the window assumption.** The fix shipped on Patch Tuesday, the bypass followed within days, and the exploitation beat the out-of-band patch. Internet-facing collaboration servers need an edge-device patch clock and an out-of-band response capability, not a monthly cadence.
- **Key rotation belongs in the runbook.** The remediation here (patch, rotate, `iisreset`) is only fast if rotation is a practiced, inventoried step. Organizations that had never rotated ASP.NET machine keys improvised it under pressure. Knowing where signing secrets live, and having a rehearsed rotation procedure, is a standing control, not an incident-time scramble.
- **Any reachable critical RCE is a ransomware precursor.** Espionage and ransomware actors used the identical entry point. Prioritization that waits to see a specific threat before acting misses that a reachable unauthenticated RCE is already enough for either outcome.

See the Vulnerability Prioritization Reference and the Edge Device Security Reference.

Cross-cutting themes

- **Patch bypasses collapse the patch window.** The fix shipped, the bypass followed within days, and the monthly cadence most on-premises fleets run could not keep up. Internet-facing collaboration servers need an edge-device patch clock.
- **Secret theft changes what remediation means.** When a vulnerability leaks a signing key, the remediation is patch plus rotate. A VM program that measures only "patched" will mark owned hosts as clean. This is the same lesson as the un-rotated LiteLLM key in the October 2026 wave.
- **On-premises is where the exposure concentrated.** The cloud edition was not affected; the servers that organizations run and must patch themselves took the damage. Self-managed internet-facing software is the persistent soft spot.

- **One exposure, many intents.** Espionage actors and ransomware actors exploited the identical entry point. Prioritization that waits for a specific threat misses that any reachable critical RCE is already a ransomware precursor.

Sources

- Microsoft Security Response Center advisories for CVE-2025-53770, CVE-2025-53771, CVE-2025-49704 and CVE-2025-49706, and the Microsoft Threat Intelligence blog on ToolShell and Storm-2603.
- CISA alert and Known Exploited Vulnerabilities entry for CVE-2025-53770 (added 20 July 2025) and the CISA malware analysis of the SharePoint activity.
- Cisco Talos, Greenbone, Eye Security, Check Point and other vendor analyses of the exploit chain and the `spinstall0.aspx` key-theft payload.
- The US National Nuclear Security Administration's confirmation, and reporting from Krebs on Security, BleepingComputer, The Record and Dark Reading on the actors and the scale.

Related references

- Edge Device Security Reference
- Vulnerability Prioritization Reference
- PHP2Shell and the October 2026 Attack Wave
- Notable Incidents, Vulnerability Management Reference